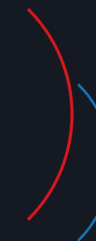


RHEL seguro na prática



Instalação segura · LVM sobre LUKS · SSH endurecido · firewalld · automação em Shell

do instalador ao hardening com evidência

A história do trabalho em uma linha

Comparamos um serviço, instalamos com criptografia, endurecemos o acesso e provamos com comandos.

1

Subscrição

Atualização, errata, suporte e propósito do sistema

2

Instalação

Partições pensadas antes do primeiro boot

3

Criptografia

LVM sobre LUKS, verificação e recriptação

4

Acesso

SSH, SELinux, firewalld e auditoria

Mensagem central

Segurança no RHEL não acontece por “marcar caixa”. Ela nasce de decisões documentadas, testadas e verificáveis.

SubscriçãoInstalaçãoCriptografiaAcesso

RHEL: o que se compra quando o código é aberto?

A subscrição não é licença de uso: é serviço continuado, atualizações, suporte e garantia operacional.

Erratas

RHSA, RHBA e RHEA entregues pelos repositórios oficiais.

Suporte

Níveis como Self-support, Standard e Premium, conforme contrato.

Certificação

Hardware, software e garantias contratuais de propriedade intelectual.

```
sudo subscription-manager register --username shadowman
sudo subscription-manager attach --auto
sudo dnf update
```

Sem subscrição, o sistema instala e roda, mas fica preso ao estado da ISO: sem erratas de segurança via repositórios.

Fluxo operacional com subscription-manager

A ordem segura é registrar, anexar a assinatura adequada e atualizar o sistema.

1

Registrar

Vincula o host à conta Red Hat.

2

Anexar

Seleciona a assinatura compatível.

3

Atualizar

Aplica erratas e correções.

```
$ sudo subscription-manager register --username shadowman  
$ sudo subscription-manager attach --auto  
$ sudo dnf update
```

Resultado esperado: sistema registrado, repositórios habilitados e pacote atualizado com segurança.

Propósito do sistema

Definir o propósito ajuda o RHEL a anexar a assinatura correta e organiza o inventário.

```
sudo subscription-manager syspurpose
{
  "addons": [],
  "role": "Red Hat Enterprise Linux Workstation",
  "service_level_agreement": "Premium",
  "usage": "Production"
}
```

role

Exemplo: Red Hat Enterprise Linux Server.

service_level_agreement

Exemplo: Premium, Standard ou Self-support.

usage

Exemplo: Production, Development ou Test.

Quando o propósito está claro, o attach automático prefere uma assinatura compatível com aquela função.

Desenhado antes de instalar qualquer coisa

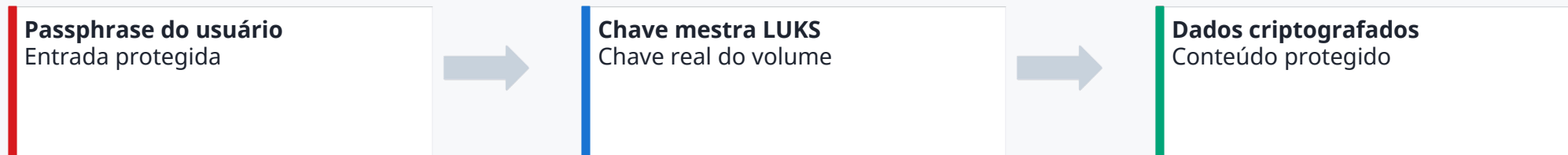
O esquema separa boot, criptografia e volumes lógicos para reduzir risco e facilitar manutenção.



Risco residual conhecido: o GRUB precisa ler kernel e initramfs antes da chave; por isso, /boot fica em claro.

O que o LUKS realmente protege

A passphrase não criptografa o disco diretamente: ela desbloqueia a chave mestra do volume.



- Uma ou mais chaves de usuário podem desbloquear a mesma chave mestra.
- No instalador do RHEL, criptografia vem desmarcada por padrão.
- Pode criptografar todo o VG ou partições específicas.

Escolha crítica do trabalho: LVM sobre LUKS — um container, uma passphrase e metadados do VG protegidos.

Da instalação ao volume já existente

Além de criptografar um disco novo, mostramos como converter um volume com dados para LUKS2.

```
# cenário de recriptação online
cryptsetup reencrypt --encrypt /dev/mapper/vg00-lv00
# saída final: written, speed 330.0 MiB/s

cryptsetup luksDump /dev/mapper/vg00-lv00
cryptsetup status lv00_encrypted
```

Evidência 1

Header LUKS válido, versão 2, UUID e cifra aes-xts-plain64.

Evidência 2

Segmento de dados criptografado após offset reservado para o header.

Evidência 3

Mapa ativo em uso: chave no keyring do kernel, não em disco.

Complementa o luksFormat em disco vazio: aqui o foco é preservar conteúdo existente sem zerar o volume.

Segundo disco: ciclo de vida a quente

O exercício mostra expansão sem parar o serviço, mantendo o novo disco também dentro de LUKS.

luksFormat

pvcreate

vgextend

lvextend

xfs_growfs

Segundo disco
~29 GB disponíveis.

Snapshots
9 GB reservados.

Expansão
20 GB para VG/LV.

- pvcreate direto em /dev/sdb deixaria metade do VG em claro.
- XFS só cresce: não existe xfs_shrink.
- Snapshot precisa de espaço livre no VG.

Cada opção bloqueia um ataque — com limite conhecido

As opções nodev, nosuid e noexec reduzem vetores comuns, mas precisam ser testadas contra atualização e operação.

Montagem	Opções	Ataque bloqueado
/tmp e /var/tmp	nodev, nosuid, noexec	Payload em área mundialmente gravável
/home	nodev, nosuid	Binário SUID criado por usuário comum
/var/log	nodev, nosuid, noexec	Staging em área de log e perda de integridade
/boot e /var	nodev (+ nosuid no /boot)	Proteção da área de boot e dados de serviço

Teste feito: /tmp/teste.sh dá Permission denied, mas bash /tmp/teste.sh executa. O noexec bloqueia o arquivo, não o interpretador.

Política de chaves: usuário não é máquina

Chaves SSH duram muito tempo; por isso, devem ser grandes, separadas por finalidade e auditáveis.

Usuário humano

Preferir ED25519. Usar RSA 4096 quando precisar de compatibilidade. Sempre com passphrase forte. Nunca copiar para outra máquina além do posto pessoal.

Máquina / automação

Sem passphrase só se for inevitável. Única por uso e inventariada. Conta restrita: nunca root/sudoer. Preferir ForceCommand e restrição por IP/VPN.

```
ssh-keygen -t ed25519 -a 100 -C "rhel-admin-2026"  
ssh-keygen -t rsa -b 4096 -C "compat-rhel-2026"  
ssh-keygen -lf ~/.ssh/id_ed25519.pub
```

Mudar porta com SELinux: ordem de sobrevivência

No RHEL com SELinux Enforcing, alterar a porta do SSH sem rótulo correto pode derrubar o acesso.

1

SELinux

```
semanage port -a -t ssh_port_t -p tcp 2222
```

2

firewalld

liberar a nova porta com limite de taxa

3

sshd

Port 2222 em drop-in dedicado

4

validação

```
sshd -t && systemctl reload sshd
```

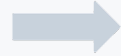
Regra de ouro

Nunca feche a sessão atual antes de validar a nova porta em uma segunda sessão aberta em paralelo.

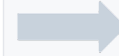
Agent forwarding: útil, mas perigoso

Quem tem root no servidor remoto pode usar seu agente enquanto a sessão estiver ativa.

Seu notebook
chave privada



Bastion remoto
root pode abusar



Host interno
acesso indireto

Alternativas mais seguras

```
ssh -J usuário@bastion host  
ProxyCommand ... -W %h:%p  
Se precisar: ssh-add -c e ssh-add -t <segundos>
```

Não habilitar por padrão. Encaminhamento de agente deve ser exceção controlada, não configuração permanente.

Política de criptografia do sistema

O jeito Red Hat é aplicar uma política consistente para SSH, TLS, Kerberos e outros serviços.

```
update-crypto-policies --set DEFAULT:NO-SHA1  
sshd -T | grep -Ei "^(ciphers|macs|kexalgorithms)"
```

Sistema inteiro

Uma decisão aplicada de forma consistente.

Menos exceção

Evita servidor fora do padrão da distribuição.

Evidência

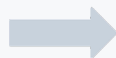
O diff das cifras antes e depois comprova a mudança.

Configurar Ciphers manualmente no sshd_config sobrepõe a política do sistema e cria desalinhamento.

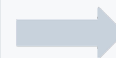
firewalld: zonas, serviços e mudanças sem reiniciar

firewalld é dinâmico: permite criar, alterar e remover regras sem reiniciar o daemon.

Interface
gerida pelo NetworkManager



Zona
nível de confiança



Serviços / portas
regras aplicadas

Onde ficam as zonas?

Predefinidas em `/usr/lib/firewalld/zones`; modificadas aparecem em `/etc/firewalld/zones`.

Regra mental

Uma conexão pertence a uma zona; uma zona pode ser usada por várias conexões.

Runtime vs permanente: teste antes de gravar

Na CLI, cada comando altera apenas o modo em execução ou apenas o modo permanente.

```
# método 1: testar e depois persistir  
firewall-cmd <opções>  
firewall-cmd --runtime-to-permanent
```

```
# método 2: gravar permanente e recarregar  
firewall-cmd --permanent <opções>  
firewall-cmd --reload
```

Decisão operacional

Para regras arriscadas: aplicar no runtime, testar conexão, validar logs e só então tornar permanente.

Sem --permanent muda apenas o estado em execução. Com --permanent, não entra em vigor até reload.

ssh-audit-harden.sh: corrigir sem derrubar a própria sessão

O script lê a configuração efetiva, aplica correção reversível e recusa mudanças inseguras.

--audit
lê sshd -T

--apply
backup + drop-in

--rollback
restaura backup

exit codes
0, 1, 2, 3

Recusas deliberadas
Não aplica AllowGroups se o grupo não existir. Não muda a porta sem SELinux e firewall prontos.

Demonstração ao vivo
Quebra MaxAuthTries, detecta NÃO CONFORME, aplica backup, valida sshd -t, recarrega e prova idempotência.

Como provar que o hardening funcionou

A apresentação ganha força quando cada decisão tem comando de validação e resultado esperado.

Criptografia

`cryptsetup luksDump + status`

SSH

`sshd -T + sshd -t`

Firewall

`firewall-cmd --list-all`

Crypto policy

`update-crypto-policies --show`

Regra: toda configuração importante deve ter evidência antes/depois ou comando de verificação.

Checklist final do ambiente

Use este slide para fechar a defesa mostrando que o ambiente foi pensado, aplicado e verificado.

Subscrição

Registrado, anexado e atualizado.

LUKS + LVM

VG protegido dentro do container.

Montagens

nodev, nosuid e noexec aplicados onde faz sentido.

SSH

Chaves, porta, SELinux, firewalld e validação.

Automação

Script com audit, apply, rollback e recusas seguras.

O que fica para a banca

Segurança é configuração, não instalação. O valor do trabalho está nas escolhas, evidências e justificativas.

1

RHEL é subscrição, atualização e suporte — não apenas a ISO instalada.

2

LVM sobre LUKS protege o VG e facilita expansão; /boot continua sendo risco residual conhecido.

3

SSH endurecido exige chave, SELinux, firewalld, política cripto e validação antes de reload.

4

LVM precisa de espaço livre: snapshot e extensão a quente preservam disponibilidade e evidência.

Perguntas?

Fontes bibliográficas principais

Fontes usadas para ambas as subscrições, LUKS, SSH, firewall e práticas de hardening.

1. RED HAT. Como usar o Subscription Manager no RHEL. Red Hat Blog. Acesso em: 16 set. 2026.

2. RED HAT. Encrypting block devices using LUKS. Red Hat Enterprise Linux 9 Security hardening. Acesso em: 16 set. 2026.

3. MOZILLA. OpenSSH guidelines. Mozilla Infosec. Acesso em: 16 set. 2026.

Continua na próxima página.

Fontes bibliográficas complementares

Continuação das fontes utilizadas no trabalho.

4.
RED HAT. Using firewalls. Red Hat Enterprise Linux 7 Security Guide. Acesso em: 16 set. 2026.

5.
RED HAT. Red Hat Enterprise Linux life cycle. Acesso em: 16 set. 2026.

6.
OPENSSSH. ssh, sshd, ssh-keygen e ssh-add manual pages. Acesso em: 16 set. 2026.

Apresentação reformulada com identidade visual, navegação clicável e caixas dimensionadas para evitar texto cortado.